

SIMATS ENGINEERING

ASSESSMENT TOOL 2(MEDIUM)

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Port Scanning Challenge

1. Using Nmap, perform a security assessment on the server 192.168.1.20. Identify all open ports and running services. Analyze the purpose of each discovered service and recommend security measures to reduce the attack surface of the system.
2. Using Nikto, assess the web server hosted on 192.168.1.30. Identify potential web server misconfigurations, outdated components, or exposed files and directories. Discuss the security risks associated with your findings and suggest appropriate mitigation strategies.
3. Using Netcat (nc), investigate the host 192.168.1.40 by connecting to open ports and collecting available service banners. Analyze the information obtained and explain how attackers could use banner information during the reconnaissance phase of an attack.
4. Using Telnet, examine the server 192.168.1.50 to determine whether remote administration services are accessible. Identify any security concerns related to the discovered services and recommend more secure alternatives where appropriate.
5. Using Netdiscover, perform host discovery on the network segment 192.168.1.1–50. Identify active hosts on the network and analyze how the discovered information could assist an attacker in planning further enumeration or exploitation activities..

Code of Conduct:

I Udhaya kumar U, 192424332 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Q.No	Identification of Port Scanning Factors(25)	Analysis(25)	Linkage(20)	Application(20)	Clarity(10)	Marks
1						
2						
3						
4						
5						

Signature of Faculty

Total Avg :

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Identification of Port Scanning Factors	25%	Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats	Identifies most factors with minor gaps	Limited or partially relevant identification	Incorrect or incomplete Port Scanning factors
Analysis	25%	Provides deep, insightful analysis of each Port Scanning component with strong reasoning	Provides good analysis with some depth	Basic analysis with limited reasoning	No meaningful analysis provided
Linkage	20%	Effectively links Port Scanning elements to derive strong strategic insights and implications	Shows some linkage with moderate insights	Weak linkage; limited strategic thinking	No linkage or strategic insight
Application	20%	Applies Port Scanning analysis effectively to the given case or scenario with clear relevance	Applies analysis with minor gaps	Limited application; lacks clarity	No clear application to context
Clarity	10%	Well-structured, clear, and logically presented with proper formatting	Generally clear with minor issues	Some structure but lacks clarity	Poorly organized and difficult to understand

Important note on the outputs in this document: The target hosts specified in the question paper (192.168.1.20, .30, .40, .50 and the 192.168.1.1–50 range) are private lab-network addresses. They are not reachable from the environment used to prepare this answer script, so the terminal outputs below are **realistic, illustrative sample outputs** modelled on how these tools behave against typical lab targets (e.g. Metasploitable2-style hosts), not a live capture from your specific lab. Run the commands exactly as shown against your actual lab VMs, and replace the sample output blocks with screenshots/text of your real results before submission — the commands, flags, and analysis are exam-accurate and will work unchanged.

Question 1 — Nmap Security Assessment of 192.168.1.20

1.1 Identification of Port Scanning Factors

Objective: enumerate open TCP/UDP ports on 192.168.1.20, fingerprint the services and OS, and identify the attack surface. A layered Nmap approach is used: host discovery → port sweep → service/version detection → OS detection → targeted NSE scripts.

Command sequence

```
# 1. Confirm host is live
$ nmap -sn 192.168.1.20

# 2. Full TCP port sweep (all 65535 ports)
$ nmap -p- -T4 192.168.1.20

# 3. Service/version detection + default scripts + OS fingerprint on discovered ports
$ nmap -sC -sV -O -p 21,22,23,25,80,139,445,3306,3389 192.168.1.20

# 4. UDP spot-check on common services
$ sudo nmap -sU -p 53,161,500 192.168.1.20
```

Sample output — full TCP sweep

```
Starting Nmap 7.94 ( https://nmap.org ) at 2026-08-11 10:02 IST
Nmap scan report for 192.168.1.20
Host is up (0.0021s latency).
Not shown: 65525 closed tcp ports (reset)

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
3389/tcp  open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 14.87 seconds
```

Sample output — service/version + OS detection

```

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.4.29 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  microsoft-ds Samba smbd 4.6.2
3306/tcp  open  mysql        MySQL 5.7.29-0ubuntu0.16.04.1
3389/tcp  open  ms-wbt-server xrdp

```

```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Aggressive OS guesses: Linux 4.15 - 5.6 (95%), Linux 5.0 - 5.4 (92%)
```

```
Network Distance: 1 hop
```

1.2 Analysis of Each Discovered Service

Port/Proto	Service	Purpose	Risk Observed
21/tcp	FTP (vsftpd)	File transfer to/from the server	Old vsftpd builds have a known backdoor CVE; c
22/tcp	SSH	Encrypted remote shell/admin access	Weak passwords or outdated OpenSSH versions
23/tcp	Telnet	Legacy remote administration	Traffic (incl. credentials) sent in clear text — trivial
25/tcp	SMTP (Postfix)	Mail transfer between servers	Open relay / user enumeration via VRFY-EXPN
80/tcp	HTTP (Apache)	Web application hosting	Unpatched Apache/app code, directory listing, ou
139/445	SMB (Samba)	Windows-style file/print sharing	Null-session enumeration, EternalBlue-class exp
3306/tcp	MySQL	Database backend	Exposed to the network instead of localhost-only
3389/tcp	RDP (xrdp)	Graphical remote desktop	Brute force, and unpatched RDP stacks are expl

The scan reveals a wide, unfiltered attack surface: nine open services spanning file transfer, shell access, mail, web, file sharing, a database, and remote desktop. The co-existence of encrypted (SSH) and unencrypted (Telnet, FTP) admin channels is the single biggest analytical red flag — it shows inconsistent hardening rather than a deliberate security baseline.

1.3 Linkage — How These Findings Connect

Individually, each open port is a minor issue; chained together they form an attack path. An attacker can use Telnet or FTP banners to fingerprint the OS/patch level (reconnaissance), then pivot to SMB for null-session user/share enumeration, use those usernames against SSH or RDP for credential stuffing, and — if MySQL is reachable from the network rather than bound to localhost — exfiltrate data once a foothold is gained via any of the above. This links directly to the CO3 outcome: port scanning results are not read in isolation but combined into a reconnaissance-to-exploitation chain.

1.4 Application — Recommended Security Measures

- Disable Telnet entirely; use SSH (key-based auth, disable root login, enforce SSHv2, fail2ban).
- Patch/upgrade vsftpd, Apache, Samba, MySQL to current stable versions; remove default/anonymous FTP.
- Bind MySQL (3306) to localhost or a private management VLAN; never expose DB ports to the general LAN/WAN.
- Restrict RDP (3389) behind a VPN or bastion host with MFA; rate-limit failed login attempts.
- Apply a host-based firewall (ufw/iptables) so only required ports are reachable from required subnets.
- Run periodic authenticated Nmap/vulnerability scans and track results in a patch-management cycle.

1.5 Clarity / Summary

Overall risk rating for 192.168.1.20: **High** — multiple legacy, clear-text and database services are exposed on the network with no evidence of network segmentation or service hardening.

Question 2 — Nikto Web Server Assessment of 192.168.1.30

2.1 Identification of Port Scanning Factors

Nikto is a web-server scanner that checks for dangerous files, outdated server software, default files/config issues, and known vulnerable components over HTTP/HTTPS. It is run after Nmap has confirmed which web port(s) — typically 80/443 — are open.

Command sequence

```
# Confirm the web port is open first
$ nmap -p 80,443 192.168.1.30

# Standard Nikto scan
$ nikto -h 192.168.1.30

# With explicit port and output saved to file
$ nikto -h 192.168.1.30 -p 80 -o nikto_192.168.1.30.html -Format htm
```

Sample output

```
- Nikto v2.5.0
-----
+ Target IP:      192.168.1.30
+ Target Hostname: 192.168.1.30
+ Target Port:    80
+ Start Time:     2026-08-11 10:20:11

+ Server: Apache/2.4.29 (Ubuntu)
+ /: The X-Content-Type-Options header is not set.
+ /: The anti-clickjacking X-Frame-Options header is not present.
+ /: Server may leak inodes via ETags, header found with file /, fields: 0x123abc
+ /icons/: Directory indexing found.
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /admin/: This might be interesting - admin directory found.
+ /config.php.bak: A backup file was found - may contain credentials.
+ /server-status: Apache mod status is enabled and reveals internal server info.
+ Apache/2.4.29 appears to be outdated (current is 2.4.6x). Multiple CVEs.
+ 7532 requests: 0 error(s) and 9 item(s) reported.
+ End Time:       2026-08-11 10:24:47 (276 seconds)
```

2.2 Analysis of Findings

Finding	Risk
Missing security headers (X-Frame-Options, X-Content-Type-Options)	Clickjacking, MIME-sniffing attacks
Directory indexing on /icons/	Reveals file/folder structure to attackers
phpinfo.php reachable	Leaks PHP version, modules, server paths, environment variables
/admin/ directory discoverable	Unauthenticated exposure of an admin login surface
config.php.bak backup file	May contain DB credentials in plain text
mod_status exposed at /server-status	Reveals live requests, internal IPs, server load
Outdated Apache version	Known, publicly documented CVEs applicable

The pattern here is configuration drift rather than a single critical flaw: none of these items alone is guaranteed to grant access, but together they leak more than enough metadata (framework, version, backup files, internal status) for an attacker to build a precise exploitation plan.

2.3 Linkage

The backup file (config.php.bak) and /admin/ discovery link directly: an attacker downloads the backup, extracts database credentials, and uses them against the discovered admin panel — turning an information-disclosure bug into full application compromise. Similarly, the exposed Apache version combines with public CVE databases to let an attacker select a pre-built exploit without any further probing, shortening the reconnaissance phase considerably.

2.4 Application — Mitigation Strategies

- Remove/rename debug and backup files (phpinfo.php, *.bak, *~, .old) from the web root.
- Disable directory indexing (Options -Indexes in Apache config).
- Add security headers: X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, HSTS.
- Restrict /server-status and /server-info to localhost or disable the modules in production.
- Patch Apache to the latest stable release and enable automatic security updates.
- Put admin panels behind authentication + IP allow-listing or a VPN, and rename default paths.

2.5 Clarity / Summary

Overall risk rating for 192.168.1.30: **Medium–High** — no remote code execution was directly demonstrated by Nikto, but information disclosure and outdated software provide a clear path to it.

Question 3 — Netcat Banner Grabbing on 192.168.1.40

3.1 Identification of Port Scanning Factors

Netcat (nc) is used here for manual banner grabbing: after Nmap identifies which ports are open, nc connects directly to each port and captures whatever banner/greeting the service sends, without the overhead of a full scan.

Command sequence

```
# Identify open ports first
$ nmap -p- --min-rate 1000 192.168.1.40

# Grab a banner from each open port
$ nc -nv 192.168.1.40 21
$ nc -nv 192.168.1.40 22
$ nc -nv 192.168.1.40 25
$ nc -nv 192.168.1.40 80

# For HTTP, send a request manually to see the response headers
$ printf 'HEAD / HTTP/1.0\r\n\r\n' | nc -nv 192.168.1.40 80
```

Sample output

```
$ nc -nv 192.168.1.40 21
(UNKNOWN) [192.168.1.40] 21 (ftp) open
220 (vsFTPd 2.3.4)

$ nc -nv 192.168.1.40 22
(UNKNOWN) [192.168.1.40] 22 (ssh) open
SSH-2.0-OpenSSH_7.6p1 Ubuntu-4ubuntu0.3

$ nc -nv 192.168.1.40 25
(UNKNOWN) [192.168.1.40] 25 (smtp) open
220 mail.local ESMTP Postfix (Ubuntu)

$ printf 'HEAD / HTTP/1.0\r\n\r\n' | nc -nv 192.168.1.40 80
(UNKNOWN) [192.168.1.40] 80 (http) open
HTTP/1.1 200 OK
Server: Apache/2.4.29 (Ubuntu)
X-Powered-By: PHP/7.2.24
```

3.2 Analysis of Banner Information Obtained

Every banner captured discloses the exact software name and version: vsFTPd 2.3.4, OpenSSH 7.6p1, Postfix on Ubuntu, Apache 2.4.29 with PHP 7.2.24. None of this required authentication — it is handed over freely as part of the normal protocol handshake, which is exactly what makes banner grabbing such a low-effort, high-value reconnaissance technique.

3.3 Linkage — Use in the Reconnaissance Phase

Banner data is the bridge between port scanning and exploitation. Once an attacker has "vsFTPd 2.3.4", they can search public vulnerability databases and immediately find that this exact build has a well-documented backdoor triggered via a crafted username. The OS distribution (Ubuntu) inferred from the SSH and SMTP banners also narrows down which kernel- and package-level exploits are relevant, and the PHP version from the HTTP banner narrows the search further to web-application CVEs. In short: banners let an attacker skip blind guessing and go straight to targeted exploit selection.

3.4 Application — Recommended Mitigations

- Suppress or generalize service banners (e.g. ServerTokens Prod / ServerSignature Off in Apache) so version numbers are not advertised.
- Keep all services patched so that even if a version is disclosed, no known exploit applies.
- Use a reverse proxy/WAF in front of web and mail services to normalize outward-facing banners.
- Monitor for repeated nc/telnet-style connection attempts as a reconnaissance indicator in IDS/IPS.

3.5 Clarity / Summary

192.168.1.40 leaks precise version information on every service tested, materially reducing the effort required for an attacker's exploit-selection phase.

Question 4 — Telnet-Based Assessment of 192.168.1.50

4.1 Identification of Port Scanning Factors

Objective: determine whether 192.168.1.50 exposes remote administration over Telnet (port 23) and, if reachable, what security posture that service reveals. Telnet is also used generically as a raw-socket client to probe other TCP ports, similar to Netcat.

Command sequence


```
# Confirm whether port 23 (Telnet) is open
$ nmap -p 23 192.168.1.50

# Attempt a Telnet connection to the admin service
$ telnet 192.168.1.50 23

# Use Telnet as a generic port prober on other services, e.g. HTTP
$ telnet 192.168.1.50 80
```

Sample output

```
$ nmap -p 23 192.168.1.50
PORT      STATE SERVICE
23/tcp    open  telnet

$ telnet 192.168.1.50 23
Trying 192.168.1.50...
Connected to 192.168.1.50.
Escape character is '^]'.

Ubuntu 16.04.6 LTS
router login: admin
Password:
Login incorrect
router login:
```

4.2 Analysis

Port 23 is open and answers with a full login banner, meaning remote administration is reachable over an unencrypted channel. Two problems compound here: (1) the banner itself discloses the OS/distribution, and (2) the entire subsequent authentication exchange — username, password, and session data — travels as plain text and can be captured by anyone positioned to sniff the network (e.g. via ARP spoofing on the same LAN segment).

4.3 Linkage

This finding connects directly to Q1 and Q3: the same host family in this lab consistently exposes legacy, clear-text management protocols alongside modern ones. An attacker who captures Telnet credentials here could reuse them against SSH, RDP, or FTP on the same or related hosts (credential reuse), turning a single sniffed login into lateral movement across the network.

4.4 Application — Recommended Secure Alternatives

- Disable the Telnet service entirely (systemctl disable --now telnetd / remove the package) and uninstall the daemon rather than just closing the port.
- Replace it with SSH for all remote administration — encrypted, supports key-based auth and MFA, and provides audit logging.
- If a legacy device genuinely requires Telnet (e.g. old network gear), isolate it on a dedicated management VLAN with strict ACLs and never expose it to the general LAN/WAN.
- Enforce account lockout after repeated failed logins to blunt brute-force attempts.

4.5 Clarity / Summary

192.168.1.50 exposes clear-text remote administration; migrating to SSH is the single highest-impact fix available for this host.

Question 5 — Netdiscover Host Discovery on 192.168.1.1–50

5.1 Identification of Port Scanning Factors

Netdiscover performs an ARP-based sweep of a network range to find live hosts, their MAC addresses, and (via the MAC OUI) the likely device vendor — all without sending a single routed IP packet, making it fast and effective on the local subnet.

Command sequence

```
# Active ARP sweep of the specified range on the correct interface
$ sudo netdiscover -r 192.168.1.0/24 -i eth0

# Passive mode (just listen to ARP traffic already on the wire)
$ sudo netdiscover -p -i eth0
```

Sample output

```
Currently scanning: 192.168.1.0/24 | Screen View: Unique Hosts

5 Captured ARP Req/Rep packets, from 5 hosts. Total size: 300

IP           At MAC Address    Count  Len  MAC Vendor / Hostname
-----
192.168.1.1   aa:bb:cc:11:22:33  1      60   TP-Link Technologies (Router)
192.168.1.20  aa:bb:cc:44:55:66  1      60   VMware, Inc.
192.168.1.30  aa:bb:cc:77:88:99  1      60   VMware, Inc.
192.168.1.40  aa:bb:cc:aa:bb:cc  1      60   VMware, Inc.
192.168.1.50  aa:bb:cc:dd:ee:ff  1      60   VMware, Inc.
```

5.2 Analysis

Five live hosts respond in the 192.168.1.1–50 range: the gateway/router at .1 and four virtualized targets (.20, .30, .40, .50) — consistent with the hosts examined in Q1–Q4. The MAC vendor field ("VMware, Inc.") is itself a useful clue: it tells an attacker the environment is virtualized, which often correlates with lab/test infrastructure that may be less tightly hardened than production hardware.

5.3 Linkage — Use in Planning Further Enumeration

Netdiscover's output is the starting point of the whole reconnaissance chain used in this challenge: it tells an attacker exactly which IPs in the subnet are worth spending time on before running Nmap (Q1), Nikto (Q2), Netcat (Q3), or Telnet (Q4) against each one individually. Without this step, an attacker would have to port-scan the entire /24 blindly, which is slower and far noisier on the network (more easily detected by an IDS). Host discovery therefore directly narrows and accelerates every later stage of the attack.

5.4 Application — Recommended Mitigations

- Segment lab/test networks from production, and treat ARP-visible ranges as sensitive.
- Use port security / DHCP snooping / Dynamic ARP Inspection on switches to make ARP-based sweeps harder to perform unnoticed.
- Deploy a network IDS (e.g. Snort/Suricata) to alert on abnormal ARP request volume, which is the signature of tools like Netdiscover.
- Minimize the number of live, reachable hosts per subnet to only what's operationally required.

5.5 Clarity / Summary

Netdiscover confirms four active targets plus the gateway in the 192.168.1.1–50 range, providing the reconnaissance map that ties directly into the findings of Questions 1–4.

Consolidated Summary

Q	Tool	Target	Key Finding	Overall Risk
1	Nmap	192.168.1.20	9 open TCP ports incl. Telnet, FTP, SMB, MySQL, RDP	High
2	Nikto	192.168.1.30	Backup file, admin dir, outdated Apache, missing headers	Medium-High
3	Netcat	192.168.1.40	Full version banners on FTP/SSH/SMTP/HTTP	Medium
4	Telnet	192.168.1.50	Clear-text remote admin login exposed	High
5	Netdiscover	192.168.1.1-50	5 live hosts identified (gateway + 4 targets)	Informational

Reminder: replace the sample terminal blocks above with your own screenshots/output captured from your actual lab VMs before submitting, and sign the Code of Conduct declaration on the original question sheet.